SYSTEMS VULNERABILITY ASSESSMENT

CYS330

VULNERABILITY ASSESSMENT (VA) AND VULNERABILITY MANAGEMENT (VM)

UNIT 1

DEFINITIONS AND BASIC CONCEPTS

- **Vulnerability Assessment (VA)** is a systematic review of security weaknesses in an information system.
- Its main goal is to;

1. **Identify Security Weaknesses –** Evaluate whether a system is prone/open to any known vulnerabilities.
2. **Assess Risk Levels –** Provide the necessary knowledge awareness and risk backgrounds to an organization to take appropriate actions against threats to its environment.
3. **Improve Security Posture –** Helps organizations understand their security weaknesses, assign severity levels, and recommend necessary remediation or mitigation measures.

DEFINITIONS AND BASIC CONCEPTS (CONTINUES…)

❑ **Mitigation**

- Is the action of reducing the severity or seriousness of something.
- Vulnerability mitigation is the process of reducing or eliminating the risk associated with a security vulnerability.
- Involves implementing measures or controls to reduce the risk and impact of identified vulnerabilities, rather than eliminating them entirely, providing temporary protection until permanent fixes or remediation can be applied.
- The primary goal for mitigation is to **lower the risk levels to an acceptable threshold**, making it tolerable for the organization or Government department.

DEFINITIONS AND BASIC CONCEPTS (CONTINUES…)

❑ Remediation

- Is the act of correcting an error.
- Vulnerability remediation is a process of eliminating detected weaknesses in your network.
- Is the process of addressing and resolving security incidences or vulnerabilities after they have been identified.
- It is **reactive** in nature meaning it occurs after a security breach or vulnerability has been detected, focusing on fixing issues and restoring normal operations.

DEFINITIONS AND BASIC CONCEPTS (CONTINUES…)

Aspect	Mitigation (Proactive)	Remediation (Reactive)
Approach	Limits damage but doesn't fix the issue	Fixes the root cause to eliminate the issue
Actions Taken	Firewalls, access controls	Patching, updates, reconfiguration
Timeframe	Short-term or temporary	Long-term or permanent
Cost	Lower upfront cost but may lead to higher expenses over time	Higher initial cost but more cost-effective in the long run.

DEFINITIONS AND BASIC CONCEPTS (CONTINUES…)

- A **vulnerability** is a weakness that can be exploited by cybercriminals to gain unauthorized access to a computer system.
- **Vulnerability Management (VM)** is the process of identifying and fixing security weaknesses in software and systems before hackers exploit them.
- A **data breach** is any security incident that results in unauthorized access to confidential information.
- A **threat** is something that can exploit a vulnerability e.g., SQLi, XSS, and Escalation of Privileges. A threat can also be defined as any potential action or event that could negatively impact an organization, its data, or its systems, aiming to steal, damage, or disrupt them.

DEFINITIONS AND BASIC CONCEPTS (CONTINUES…)

- **Risk** is the damage caused when a threat exploits a vulnerability or can refer to the potential for loss, damage, or harm to an organization's assets or reputation resulting from threats and vulnerabilities.
- **Threat intelligence** involves collecting, analyzing, and sharing data about cyber threats to empower security teams to take proactive measures for detecting, mitigating, and preventing cyberattacks.

DEFINITIONS AND BASIC CONCEPTS (CONTINUES…)

❑ **Common Vulnerability Scoring System (CVSS)**

- Is used to asses and communicate the severity of software vulnerabilities.

Low	Medium	High	Critical
0.1 – 3.9	4.0 – 6.9	7.0 – 8.9	9.0 – 10.0

- It provides a numerical score ranging from 0 to 10 to help organizations prioritize their remediation efforts.

DEFINITIONS AND BASIC CONCEPTS (CONTINUES…)

- **Asset inventory** identifies assets to assess or is a comprehensive list, record, and management system of an organization's assets, both physical and digital, including hardware, software, and other resources, to ensure their proper tracking, utilization, and security.
- **Risk Prioritization** helps understand business impact and priorities vulnerabilities.
- **Reporting and Remediation** is develop processes for reporting and addressing vulnerabilities.
- A **process** is conducted using automated tools which results in a report detailing vulnerabilities.
- Software **patching** is an update released to address specific issues in a program. Issues include bugs, security vulnerabilities or performance enhancements.

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

TYPES OF VULNERABILITIES

1. **Application vulnerabilities**

- Are flaws or weaknesses in software code that can be exploited by malicious actors, potentially leading to security breaches and data compromise.
- Like **broken access control**, **SQL injection**, and **cross-site scripting (XSS)**, can lead to unauthorized access, data breaches, and system compromise.

TYPES OF VULNERABILITIES (CONTINUES…)

2. **Configuration Vulnerabilities**

- Are flaws or weaknesses in a system's security settings, arising from improper configuration, that can be exploited by attackers to gain unauthorized access or compromise the system.
- Examples include leaving **default credentials**, **misconfigured firewalls**, or **open ports**.

TYPES OF VULNERABILITIES (CONTINUES…)

3. **Network Vulnerabilities**

- Are weaknesses or flaws in a network's hardware, software, or configuration that can be exploited by attackers to gain unauthorized access to the network.
- It encompass various weaknesses that can be exploited by attackers, including **outdated software, misconfigured firewalls, weak passwords, unsecured access points, phishing attacks, insider threats**, and **malware.**

TYPES OF VULNERABILITIES (CONTINUES…)

4. **Operating System (OS) Vulnerability**

- Is a loophole or flaw in your operating system that makes it easier for cybercriminals to break in.
- Examples include **malware, misconfigurations, broken authentication, injections, buffer overrun, remote code execution, unpatched software,** and **privilege escalation.**

WHY SECURITY FAIL

1. **Outdated Software and Misconfigurations**

i. **Cloud Misconfigurations** – Default settings, inadequate permissions, insufficient monitoring and unpatched vulnerabilities are all misconfigurations here.

ii. **Improper Access Controls** – Granting excessive permissions increases the risk of unauthorized access.

iii. **Unpatched Systems** – Delayed updates leave known vulnerabilities open to exploitation.

WHY SECURITY FAIL (CONTINUES…)

2. **Resource Allocation**

- Prioritization is crucial, this simply means that not all vulnerabilities pose the same risk.
- Organizations struggle with allocating resources effectively to address critical vulnerabilities first

WHY SECURITY FAIL (CONTINUES…)

3. **Human Error and Oversight**

- Missed vulnerabilities due to oversight or misinterpretation can occur.

i. **Weak Password Practices** – such as default passwords, and reused passwords opens a system to vulnerability to brute force or credential stuffing attacks.

ii. **Phishing and Social Engineering** – Employees falling for phishing emails or scams can expose sensitive credentials or download malware.

iii. **Misplaced Devices** – Losing devices such as laptops or mobile phones with sensitive data can lead to breaches.

WHY SECURITY FAIL (CONTINUES…)

4. **Lack of Remediation Plan**

- Organizations need to create properly calculated action plan for remediation.
- Delayed incidence response could be as a result of not having a remediation plan in the first place.
- Security issues that are not addressed on time can escalate causing significant

i. disruption to business operations and downtime,

ii. loss of productivity, and

iii. damage to reputation.

WHY SECURITY FAIL (CONTINUES…)

5. **Compliance Requirements**

- It is a must for all organizations locally and internationally to comply to industry standards.
- Managing vulnerabilities also helps organizations and Government Departments comply with regulations and standards, such as General Data Protection Regulation (GDPR) by the EU and ZICTA specifically, overseeing all data related compliances in Zambia.

WHY SECURITY FAIL (CONTINUES…)

6. **False Positives and False Negatives**

i. **False Positives** – occurs when a security system mistakenly identifies a legitimate action (does not pose a threat) or occur when a vulnerability is flagged that doesn't exist.

ii. **False Negatives** – occur when a real vulnerability is missed or when a security system fails to detect a real threat or malicious activity.

WHY SECURITY FAIL (CONTINUES…)

7. **Lack of Human Resource**

- This means that very few are actually trained in handling cyber security matters in organizations and Government Departments.
- This may also lead to lack of security awareness by employees in an organization.
- Employees could make grave mistakes such as clicking on malicious links or mishandling sensitive company data.
- With adequately trained human resource, vulnerabilities could easily be delt with.

DIFFERENCE BETWEEN VA AND VM

Aspect	Vulnerability Assessment	Vulnerability Management
Definition	A **one-time process** to identify and evaluate security vulnerabilities in IT systems and networks	An **ongoing, continuous process** to identify, prioritize, remediate, and monitor vulnerabilities
Scope	Focuses on discovering and reporting vulnerabilities at a specific point in time	Encompasses the entire life cycle of vulnerability handling, including assessments, remediation, and monitoring
Frequency	**Conducted periodically** e.g., quarterly or annually	**Performed continuously** to maintain up to date security
Goal	Identifies weaknesses but does not address or fix them	Aims to reduce the attack surface by addressing vulnerabilities systematically
Tools used	Nessus or OpenVAS	Qualys or Rapid7

NEED (IMPORTANCE) OF VULNERABILITY ASSESSMENT (VA) AND VULNERABILITY MANAGEMENT (VM)

1. Identification of Security Weaknesses
2. Prioritization of Threats (Assessing Risk Levels)
3. **Compliance with Regulations**
4. Minimizing Internal and External Attacks
5. Faster Remediation of Vulnerabilities
6. Enhanced Security Posture

NEED (IMPORTANCE) OF VULNERABILITY ASSESSMENT (VA) AND VULNERABILITY MANAGEMENT (VM)

7. **Maintaining Customer Trust**
8. **Cost Savings from Reduced Data Breaches**

Other Importance (need) for VM

1. Proactive Risk Reduction
2. Asset Protection
3. Business Continuity

TYPES OF VULNERABILITY ASSESSMENTS

1. **Host Based – Scan**

- This type of assessment, locates and identifies vulnerabilities in individual systems such as **servers**, **workstations**, and other network hosts.
- The focus is on critical servers which maybe vulnerable to attacks. The server scan include:

i. Open ports

ii. Patches

iii. Updates

iv. Configurations

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

- **Host Based – Scan Mitigation Plan**

i. **Adopt a Zero-Trust Security Model –** by treating every access request as untrusted, requiring verification of user identification and device health before granting access especially in complex environments where resources are accessed from various locations to protect middleware attacks.

ii. **Use Web Application Firewalls (WAFs)** – to monitor and filter HTTP traffic between a web application and the internet in order to provide an additional layer of security against common web exploits.

iii. **Firmware Integrity Checks –** such as **hashing techniques** to verify that the firmware has not been altered or tampered with during storage or transmission.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

- **Host Based – Scan Mitigation Plan (Continues…)**

iv. **Encryption**

v. **Secure Firmware Updates by Digital Signatures** – to prevent unauthorized modification during transmission.

vi. **Buffer and Stuck Overflow Protection** – to protect firmware.

vii. **Access Control Management (Least Privilege Principle)** – Use **Security Descriptor Definition Language (SDDL)** strings to control access to device objects, ensuring that only authorized users can interact with them.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

- Security Descriptor Definition Language (SDDL)

O:BAG:SYD: = user or group and Built-in Administrators

(A;;CCLCSWRPWPDTLOCRRC;;;SY) Security Identifier for Local system

(A;;CCDCLCSWRPWPDTLOCRDRC;;;BA) = Allow and Permission Granted

(A;;CCLCSWLOCRRC;;;IU) = Discretionary Access Control List (DACL)

(A;;CCLCSWLOCRRC;;;SU)S = Service Users and System Access

(AU;;FA;CCDCLCSWRPWPDTLOCRSDRC;;;WD) = Audit, Everyone Full Access

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

2. **Network – Based Scan**

- It focuses on identifying vulnerabilities in wired and wireless networks.
- They help detect vulnerability systems within an organization's network infrastructure.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

3. **Application Based – Scan**

- Here, we identify the vulnerabilities in **web applications** and their **source code** and **configurations**.
- In this type we test the code to make sure that there are no vulnerabilities.
- Tests can be done to make sure that application is safe.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

❑ **Application Based – Scan (Continues…)**

- Scan for outdated libraries and insecure coding practices. It can be both **static** and **dynamic** analysis .
- **SAST** analyses the source code or binaries of an application without executing it. It helps identify vulnerabilities early in the development process.
- **DAST** tests the application in a running state to identify vulnerabilities that manifest during execution, such as input validation errors and session management issues.
- We can also conduct a **configuration review** and **Penetration Testing**.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

4. **Application Programming Interface (API) Vulnerability Based – Scan**

- An **API (Application Programming Interface)** is a set of rules and protocols that allows different software applications to communicate with each other.

i. **Web APIs** – Used for web-based communication (e.g., RESTful APIs, GraphQL, SOAP).

ii. **Library APIs** – Provide functions within a programming library (e.g., SFML for C++).

iii. **Operating System APIs** – Allow software to interact with OS features (e.g., Windows API).

iv. **Hardware APIs** – Enable software to interact with hardware (e.g., DirectX for graphics).

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

How APIs Work

i. A client (e.g., a web app or program) sends a **request** to the API.

ii. The API processes the request, interacts with the database or external service, and sends back a **response**.

iii. The client receives and processes the response.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

API Vulnerabilities in Mobile Money Services

i. **Weak Authentication & Authorization** – If an API only requires a simple 4-digit PIN without additional verification, an attacker can brute-force it to access a user's account.

ii. **Insecure API Endpoints** – APIs that **expose sensitive user data** (e.g., **account details,** transaction history) without proper access control.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

iii. **Lack of Rate Limiting** – APIs without request limits allow brute-force attacks and Denial-of-Service (DoS) attacks. For example, a bot sends thousands of login attempts per second, guessing user PINs and overwhelming the system.

iv. **Man-in-the-Middle (MITM) Attacks** – Weak encryption lets attackers intercept and modify financial transactions. For example, if an API transmits sensitive data over HTTP instead of HTTPS, an attacker on the same network can capture login credentials.

v. **Injection Attacks** – Poor input validation allows SQL or command injections to steal or alter data

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

Implications of API Vulnerabilities in Mobile Money Services

i. Financial Loss

ii. Data Breaches

iii. Service Disruptions

iv. Legal Consequences

v. Reputation Damage

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

Mitigation Strategies for API Security in Mobile Money Services

i. Implement Multi-Factor Authentication (MFA)

ii. Enforce strong password and PIN policies

iii. Apply Role-Based Access Control (RBAC)

iv. Encrypt sensitive data with TLS 1.2

v. Implement rate limiting

vi. Use Web Application Firewalls (WAF)

vii. Apply CAPTCHA for repeated login attempts

viii. Validate and sanitize user inputs

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

Remediation Plans for API Security in Mobile Money Services

i. Patching

ii. Awareness and Training

iii. Finding the root cause (Vulnerability Assessment)

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

5. **Cloud – Based Scan**

- The cloud refers to servers that are accessed over the Internet, and the software and databases that run on those servers.
- All resources in the infrastructure such as **applications**, **servers**, **databases** and **network** configurations, should be scanned to detect security weaknesses such as outdated software.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

Cloud Services

i. Infrastructure as a Service (IaaS)
ii. Platform as a Service (PaaS)
iii. Software as a Service (SaaS)
iv. Containers as a Service (CaaS)
v. Functions as a Service (FaaS)

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

Types of Clouds

i. Private

ii. Public

iii. Hybrid

- Amazon (2006)
- Azure (2010)
- Google cloud (2013)

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

- Every time, we need a new business app, we end up buying a new physical server.
- With **virtualization**, this problem as been delt with.
- A **hypervisor** is software or firmware that creates and manages **Virtual Machines (VMs)** by allowing multiple operating systems to run on a single physical machine.

TYPES OF VULNERABILITY ASSESSMENTS (CONTINUES…)

Types of Hypervisors

i. **Type 1 (Bare-Metal Hypervisor)** – Runs directly on the hardware without an underlying operating system. For example, VMware ESXi, **Microsoft Hyper-V**, and KVM.

ii. **Type 2 (Hosted Hypervisor)** – Runs on top of an existing operating system. For example, **VirtualBox, VMware Workstation.**

VULNERABILITY ASSESSMENT PROCESS

1. **Vulnerability Identification (Testing)**

- In this step, creation of a list (using inventory) of vulnerabilities are identified in the system by using scanning tools.
- Furthermore, vulnerabilities are related to their threats e. g, unpatched Windows server.

VULNERABILITY ASSESSMENT PROCESS (CONTINUES…)

2. **Vulnerability Analysis**

- The primary objective of this step is to identify the source and root cause of the vulnerabilities identified earlier.

VULNERABILITY ASSESSMENT PROCESS (CONTINUES…)

3. **Risk Assessment**

- Here, **prioritization** of vulnerabilities takes place by ranking them and assign a severity scope to each vulnerability.
- Visit **slide 9** to understand the severity levels using the CVSS.

VULNERABILITY ASSESSMENT PROCESS (CONTINUES…)

4. **Remediation**

i. Implementing **strong passwords policies** and **multi-factor authentication**

ii. **Updating** or **changing configurations** of systems

iii. Apply new security systems such as **firewalls**

iv. **Train employees** on recognizing phishing and social engineering attacks.

v. Conduct **regular security audits** and **vulnerability assessments**

VULNERABILITY ASSESSMENT METHODOLOGY

1. **Breadth of Assessment**

- Simply means the **scope** of and extend of the assessment.
- It involves deciding which networks, systems, applications, and digital assets will be included in the assessment.
- Examples include Network, Application, API, Host, Cloud – Based Assessment etc..

VULNERABILITY ASSESSMENT METHODOLOGY (CONTINUES…)

2. **Depth of The Vulnerability Assessment**

- This pertains to the **granularity** (**details** of the context of vulnerability assessments) of the examination conducted on each asset.
- Depth Assessment Tools include;

i. **Fuzzers –** is an automated software testing technique used to identify bugs and security vulnerabilities by feeding a program with invalid, unexpected or random inputs. **Random fuzzing, Template evolution fuzzing** and **geratioanel fuzzing** are the common fuzzing.

VULNERABILITY ASSESSMENT METHODOLOGY (CONTINUES…)

3. **Frequency of Assessment**

- The interval between each test or check can vary by the type of asset being tested.

VULNERABILITY ASSESSMENT TEAM

1. **Leadership**
   i. Project Managers
   ii. Policy and Strategy
   iii. IT Security Officer

2. **Technical Teams**
   i. Vulnerability Assessment Analysts
   ii. Penetration Testers
   iii. Red Team
   iv. Blue Team
   v. Incident Response
   vi. Vulnerability management

VULNERABILITY ASSESSMENT TEAM (CONTINUES…)

3. **Support Functions**

i. Documentation and Reporting

ii. Training and Awareness

iii. Quality Assurance

iv. Communication and Coordination

4. **Collaboration with other Departments**

i. Compliance and Legal

5. **Continuous Improvement and Research**

OPERATING SYSTEM

SCHEDULING ALGORITHMS

HARDWARE TROJANS (HT)

- A **hardware trojan** is a malicious modification of an integrated circuit's circuitry, designed to disrupt operations, steal data, or cause physical harm or death.
- These modifications can be inserted during the design or manufacturing stages, often through untrust third-party components or intellectual property cores.

CHARACTERISTICS OF HARDWARE TROJANS

1. **Size** – This refers to the number of components added or modified. Trojans can range from **small transistors** to **large circuits**.
2. **Distribution**

i. **Tight Distribution** – Trojan components are located close together in the layout.

ii. **Loose Distribution** – Components are dispersed across the chip making detection harder

CHARACTERISTICS OF HARDWARE TROJANS (CONTINUES…)

3. **Structure** – Changes in the physical layout can alter the chips (IC) dimensions or component placement.
4. **Type**

i. **Functional Trojans –** These involve adding or deleting components such as transistors or logic gates to modify chip's functionality.

ii. **Parametric Trojans** – These involve modifying existing components such as thinning wires or weakening transistors, to affect the chip's reliability or performance.

IMPACT OF HARDWARE TROJANS

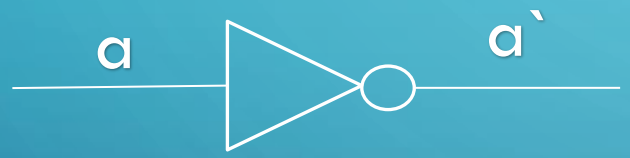
1. Data Breaches and Intellectual Property Theft
2. System Malfunction
3. Performance Degradation
4. Reputational Damage and Financial Costs
5. Denial – of – service (DoS) Attacks

MITIGATION AND REMEDIATION TECHNIQUES OF HT

1. Detection Techniques
2. Collaborative Methods
3. Message Authentication Codes (MACs)

LOGIC GATES

1. NOT



TRUTH TABLE

INPUT (a)	OUTPUT (a`)
1	0
0	1

LOGIC GATES (CONTINUES…)

2. AND



TRUTH TABLE

INPUT (a)	INPUT (b)	OUTPUT (ab)
0	0	0
0	1	0
1	0	0
1	1	1

LOGIC GATES (CONTINUES…)

3. OR



TRUTH TABLE

INPUT (a)	INPUT (b)	OUTPUT (a + b)
0	0	0
0	1	1
1	0	1
1	1	1

QUESTION

Calculate the average waiting time and average turnaround time. For:

1. First Come First Serve (FCFS) Scheduling Algorithm

FIRST COME FIRST SERVED SCHEDULING

PROCESS ID (PID)	ARRIVAL TIME	BURST TIME
1	4	5
2	6	4
3	0	3
4	6	2
5	5	4

PID	C.T	T.A.T	W.T
1	9	5	0
2	17	11	7
3	3	3	0
4	19	13	11
5	13	8	4

Average = 8 4.4 units

T.A.T = C.T – ARRIVAL TIME

W.T = T.A.T – BURST TIME

C.T = Completion Time

T.A.T = Turn Around Time

W.T = Waiting Time

Gantt Chart

TIME	0	3	-	-	-	4	9	13	17	19
PID		3	Idle time				1	5	2	4

Calculations

0 + 3 = 3

4 + 5 = 9

9 + 4 = 13

13 + 4 = 17

17 + 2 = 19

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

FIRST COME FIRST SERVED SCHEDULING (CONTINUES…)

- **Convoy Effect**

If process with higher burst time arrived before the processes with smaller burst time, then, smaller processes have to wait for a long time for longer processes to release the CPU.

SHORTEST JOB FIRST – NON PRE-EMPTIVE

PROCESS ID (PID)	ARRIVAL TIME	BURST TIME
0	0	7
1	2	4
2	4	1
3	5	4

PID	C.T	T.A.T	W.T
0	7	7	0
1	12	10	6
2	8	4	3
3	16	11	7

Average = 8 4 units

T.A.T = C.T – ARRIVAL TIME

W.T = T.A.T – BURST TIME

Gantt Chart

TIME	0	7	8	12	16
PID		0	2	1	3

Calculations

0 + 7 = 7

7 + 1= 8

8 + 4 = 12

12 + 4 = 16

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

SHORTEST JOB FIRST – PRE-EMPTIVE

PROCESS ID (PID)	ARRIVAL TIME	BURST TIME
0	0	7 – 2 = 5
1	2	4 – 2 = 2
2	4	1
3	5	4

PID	C.T	T.A.T	W.T
0	16	16	7
1	7	5	1
2	5	1	0
3	11	6	2

Average = 7 2.5 units

Gantt Chart

TIME	0	2	4	5	7	11	16
PID		0	1	2	1	3	0

Read Queue

TIME	5	2	4
PID	0	1	3

T.A.T = C.T – ARRIVAL TIME

W.T = T.A.T – BURST TIME

PRIORITY SHEDULING ALGORITHM

Consider the lowest number to be the highest priority

PRIORITIVE	PROCESS ID (PID)	ARRIVAL TIME	BURST TIME
3	0	0	7
2	1	2	4
4	2	4	1
1	3	5	4

PID	C.T	T.A.T	W.T
0	7	7	0
1	15	13	9
2	16	12	11
3	11	6	2

Average = 9.5 5.5 units

Gantt Chart

TIME	0	7	11	15	16
PID		0	3	1	2

T.A.T = C.T – ARRIVAL TIME

W.T = T.A.T – BURST TIME

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

VULNERABILITY RESEARCH

UNIT 2

VULNERABILITY RESEARCH

- It is actively involved in discovering critical vulnerabilities in software and hardware products as part of its ongoing research and development efforts.
- It **aims to improve security** by discovering unexpected behavior or vulnerabilities that could be exploited by attackers.
- **Techniques** used for vulnerability research include **code auditing, fuzzing,** and **reverse engineering.**

1. **Disassembler**

- Breaks down executable files into assembly code.
- Is used for **reverse engineering, debugging, malware analysis.**

i. **IDA Pro** – analyzes complex binaries and those from embedded systems included as well as mobile applications.

ii. **Binary Ninja** – cross platform compatibility and scripting for disassembling, decompiling, and debugging binary files.

iii. **Ghidra** – It is an open-source reverse engineering tool developed by the National Security Agency (NISA) and available on Windows, MacOS and Linux.

2. Debugger

- Allows dynamic analysis with breakpoints in programming.

i. **GDB/GNU** – This is a powerful and versatile debugging tool used for examining the internal operation of running programs.

ii. **Windows Debugger (WinDBG)** – This is a powerful tool developed by Microsoft for debugging windows applications, drivers, and the operating system.

iii. **OllyDbg** – It is a 32-bit assembler level debugger for windows, widely used in RE and malware analysis. It is useful when source code is not available, as it allows users to analyze binary code directly.

3. **Decompile** – Converts machine code into high-Level code for easier analysis.
4. **Scripting** – Supports automation and customization.
5. **Extensibility** – Users can develop plugins (extensions) to enhance functionality.

VULNERABILITY RESEARCH ASPECTS

- Some key discovery include the following;

1. **Vulnerability discovery** – focuses on identifying critical vulnerabilities in both software and hardware.
2. **Threat Analysis** – The analysis helps to determine the intended purpose of threats, the skill level of their authors, and their relationship to previously analyzed malware.

VULNERABILITY RESEARCH ASPECTS (CONTINUES…)

3. **Security Evaluation** – Vulnerability Research adopts an offensive mindset to evaluate security through pen test to see if an organization's security plans and posture can withstand sophisticated attacks.
4. **Vulnerability Research** – can also foster a collaborative determined environment that It brings forth value innovation, teamwork and impactful work.
5. **Mitigation** – Providing recommendations for patching or securing identified vulnerabilities to prevent exploitation.

WEB PROXIES

- This is an intermediary server that facilitates communication between a client device such as a web browser and the destination server.

1. **Burp Suite** – This is a comprehensive tool for web application security testing, features include;

i. **Proxy** – used for intercepting.

ii. **Scanner** – automatically scans web applications for vulnerabilities.

iii. **Intruder** – automates customised attacks.

iv. **Repeater** – resends HTTP requests.

v. **Decoder and Comparer** – used for decoding and comparing data to aid in analyzing.

WEB PROXIES (CONTINUES…)

2. **OWASP ZAP (Zed Attack Proxy)**

- Used for identifying vulnerabilities in web applications.
- It can be used for both passive and active scanning.
- It is also effective for JavaScript-heavy applications.

3. **Charles Proxy** – This is a web debugging tool that acts as a man-in-the-middle for HTTP/HTTPS communication, allowing developers to inspect and modify network traffic.

CODE REVIEW TOOLS

- This is a software application designed to assist developers in reviewing and managing code changes with version control systems.

1. **GitHub** – used for collaboration, primarily designed for hosting and managing software development projects.
2. **GitLab** – is a comprehensive platform that provides tools for version control.

FILE FORMAT ANALYSIS

- This is the process of **examining** the structure, content, and metadata of files to understand their formats, identify potential issues or extract useful information commonly used in **digital forensics**, **reverse engineering**, malware analysis, and software development.

1. **Binwalk**
2. **TrID file Identifier –** It helps analyze unknown files and determine their formats.
3. **PE viewer –** used to analyze and view the structure of PE files, which are executable files used by windows.

VULNERABILITY CATEGORIES

1. Misconfigurations

- A misconfiguration happens when something isn't set up correctly like leaving default passwords, incorrect permissions, open ports, or wrong settings which can create problems or open doors for attackers.
- Errors during manual configuration can lead to vulnerabilities.
- Organizations and Government Departments should adopt security tools, automate configurations, and reduce human error risks.

VULNERABILITY CATEGORIES (CONTINUES…)

2. **Unsecured Application Programming Interfaces (APIs)**

- Are APIs that lack proper security measures, making them vulnerable to attacks, unauthorized access, or misuse.
- This can be caused by;

i. No authentication or weak authentication
ii. Improper authorization
iii. Lack of encryption
iv. Exposing sensitive data
v. Rate limiting missing

VULNERABILITY CATEGORIES (CONTINUES…)

3. Outdated and unpatched software

- Running outdated or unpatched software exposes systems to known vulnerabilities.
- Regular software updates and patches are important to mitigate risks.

VULNERABILITY CATEGORIES (CONTINUES…)

4. **Zero day (0 – day) vulnerabilities**

- These are unknown and unpatched.
- An attack that exploits computer applications vulnerabilities before the software developer releases a patch for the vulnerability.

VULNERABILITY CATEGORIES (CONTINUES…)

Characteristics of Zero-Day Vulnerabilities

a) Undiscovered at Release

b) Long Periods of Invisibility

c) Exploitation in Zero-Day Attacks

VULNERABILITY CATEGORIES (CONTINUES…)

5. **Window of vulnerability**

- Is the time from when a software exploit first becomes active to when the number of vulnerable systems shrinks significantly.

a) **t0** – The vulnerability is discovered

b) **t1a** – A security patch is published by the software vendor

c) **t1b** – An exploit becomes active

d) **t2** – Most vulnerable systems have applied the patch.

VULNERABILITY CATEGORIES (CONTINUES…)

- The formular for the **length of the window of vulnerability** is: **t2 – t1b**

COMMON VULNERABILITY EXPOSURES (CVE)

- CVE is a standard used to **identify**, **define**, and **catalog** publicly disclosed cybersecurity vulnerabilities.
- CVE provides a common language for discussing and sharing information about security vulnerabilities.

i. **CVE Records** – include details about specific vulnerabilities. Each vulnerability is assigned a unique **CVE identifier**.

ii. **CVE list** – contains CVE records.

iii. **CVE Numbering Authority (CNAs)** – add the CVE records to the CVE list.

iv. **NVD (National Vulnerability Database)** – maintained by NIST.

SENSITIVE DATA EXPOSURE (SDE)

- This issue revolves around the accidental or deliberate **disclosure** of critical information, such as:

i. **Personally Identifiable Information (PII)** – This includes data like **Social Security numbers** (NAPSA), **addresses** (physical and work related).

ii. **Payment Card Information (PCI)** – Credit card numbers, expiration dates, and security codes.

iii. **Intellectual Property (IP)** – Trade secrets.

BINARY

UNIT 2.1

HOW TO CONVERT A DECIMAL NUMBER INTO BINARY (POWERS OF 2)

- To achieve this will utilize the **powers of 2.**

2 ^ 0 = **1**

2 ^ 1 = **2**

2 ^ 2 = **4**

2 ^ 3 = **8**

2 ^ 4 = **16**

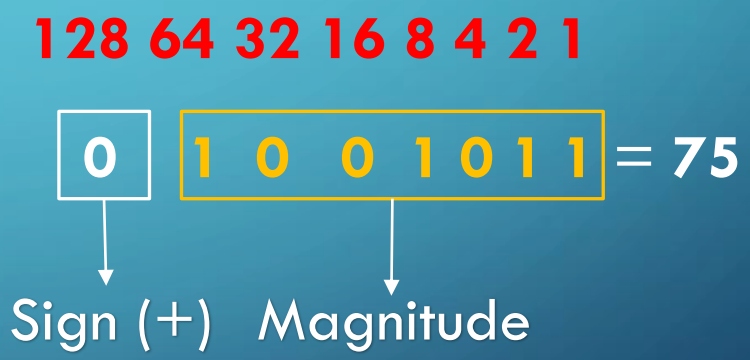
2 ^ 5 = **32**

2 ^ 6 = **64**

2 ^ 7 = **128**

```
>>> bin(75)
'0b1001011'
>>>
```

- For example, let's convert **75** into binary



HOW TO CONVERT A DECIMAL NUMBER INTO BINARY (POWERS OF 2) (CONTINUES…)

- Let's take another example of **339**

512 256 128 64 32 16 8 4 2 1

0 | **1 0 1 0 1 0 0 1 1** = 339

Sign (+) Magnitude

- **1 = True**
- **0 = False**

```
>>> int(True)
1
>>> int(False)
0
>>>
```

```
>>> bin(339)
'0b101010011'
>>>
```

HOW TO CONVERT A DECIMAL NUMBER INTO BINARY SUCCESSIVE DIVISION

- Now, let's use **successive division** to find the binary of *75*

75 / 2 = 37 R **1**

37 / 2 = 18 R **1**

18 / 2 = 9 R **0**

9 / 2 = 4 R **1**

4 / 2 = 2 R **0**

2 / 2 = 1 R **0**

1 / 2 = 0 R **1**

- We now get the binary from the bottom to the top, making it:

1001011

```
>>> bin(75)
'0b1001011'
>>> 0b1001011
75
>>>
```

HOW TO ADD BINARY NUMBERS

- Here are some basics of addition:

0 + 0 = **0**

0 + 1 = **1**

1 + 0 = **1**

1 + 1 = **10**

```
    1
+   1
____
```

```
>>> bin(1+1)
'0b10'
>>>
```

1 **0**, this is the same as 1 + 1 = 2

2 / 2 = **1** R **0**

HOW TO ADD BINARY NUMBERS (CONTINUES…)

```
    1
    1
+   1
-----
  1 1
```

```
>>> bin(1+1+1)
'0b11'
>>>
```

This is the same as 1+1+1 = 3

3 / 2 = **1** R **1**

- **NOTE:** On the bottom we are putting the **reminder** (**R**) and **carrying** the number of times 2 enters into the target number.

HOW TO ADD BINARY NUMBERS (CONTINUES…)

- Let's take an example below:

```
  1 0 1 0  = 10
+ 1 0 0 1  =  9
-----------  ---
  1 0 0 1 1 = 19
```

16	8	4	2	1	Decimal
	1	0	1	0	10
	1	0	0	1	9
1	0	0	1	1	19

```
>>> bin(10)
'0b1010'
>>> bin(9)
'0b1001'
>>> bin(19)
'0b10011'
>>>
```

HOW TO SUBTRACT BINARY NUMBERS

- Here are some basics of subtraction:

1 - 0 = 1

1 - 1 = 0

```
>>> bin(8-1)
'0b111'
>>>
```

	1	1	
0	~~2~~	~~2~~	2
~~1~~	~~0~~	~~0~~	0
-			1
0	1	1	1

→

8	4	2	1
8			
-			1
			7

1 0 → 0 2

- 1 → 1

1 In base 2, will get a 2 from the nearest value.

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

1'S & 2'S COMPLEMENT

1'S COMPLEMENT

- Obtain 1's complement of **1010**.
- **NOTE:** In ones complement we **slip** the numbers, 1 becomes 0 and 0 becomes 1.
- Therefore 1's complement of **1010** is **0101**.

2'S COMPLEMENT

- Formular:

  2's complement = 1's complement + 1

QUESTION: Obtain 1's complement of **10111010**.

1s complement = **01000101**

2s complement = **01000110**

SIGNED MAGNITUDE

CONVERTING A BINARY

- Let's take an example, let's express (**-6**) using the signed magnitude.

1. What is (**+6**) in binary?

8 4 2 1

0 1 1 0 = +6

Sign (+) ← 0 | 1 1 0 → Magnitude

NEGATIVE BINARY REPRESENTATION

2. The **Sign (+)** will change from **0** to **1** **Sign (-).**

8 4 2 1

Sign (-) ← 1 1 1 0

NOTE: 1 represent **negative** and **0** **positive**

2'S COMPLEMENT

NEGATIVE NUMBERS

- Represent **-12** in binary using the 2's complement.

16 8 4 2 1

0 1 1 0 0 = **12**

1 0 0 1 1 = 1's complement

2'S COMPLEMENT (-12)

1 0 0 1 1

\+ 1

---

1 0 1 0 0 = **-16** + **4** = **-12**

Sign (-) Magnitude

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

2'S COMPLEMENT SUBTRACTION

BINARY CONVERSATION

- Let's subtract **39 – (25).**
- Using normal math operation 39 – 25 = 14.

1. Convert 39 and 25 into binary.

64 32 16 8 4 2 1

0 1 0 0 1 1 1 = **39**

- 0 0 1 1 0 0 1 = **25**

0 0 0 1 1 1 0 = **14**, Proof (8+4+12)

1'S & 2'S COMPLEMENT

2. Find the 1's complement 25.

1 1 0 0 1 1 0 = **25** 1's complement

3. Find the 2's complement of 25.

1 1 0 0 1 1 1 = **25** 2's complement

NOTE: We are targeting **25,** because in 2's complement subtraction we **change the sign** of the number after the minus (-) sign, so **25** becomes **-25.**

2'S COMPLEMENT SUBTRACTION (CONTINUES…)

2'S COMPLEMENT SUBTRACTION

4. Finally, do the 2's complement subtraction of 39 and 25.

  0 1 0 0 1 1 1

+1 1 0 0 1 1 1

(1) 0 0 0 1 1 1 0

NOTE: We have a carry 1 at the end, but we are just ignoring it, meaning an **overflow** as occurred.

VERIFICATION

- Is 0001110 14?

  128 64 32 16 8 4 2 1

  0 0 0 0 1 1 1 0

- 8 + 4 + 2 = 14, **NOTE:** In 2's complement subtraction we **add** two binaries, think of it as 39 – 25 is the same as 39 + (-25).

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

PERT CHART

UNIT 2.2

BENEFITS OF A PERT CHART

- **Program Evaluation and Review Technique (PERT) chart** is a project management tool used to plan, schedule, and coordinate tasks within a project by visually mapping activities and their dependencies.
- **Benefits** of a PERT Chart include;

1. Visualization of dependencies
2. Critical path identification
3. Effective time management
4. Risk management
5. Clear communication
6. Resource optimization
7. Project monitoring and control

CHALLENGES OF PERT CHARTS

LIMITATION

- The accuracy of the PERT chart depends heavily on the quality of the estimates for the activity times.

KEY FEATURES

1. **Optimistic time (O/to)** – Shortest duration if everything goes perfectly.
2. **Pessimistic time (P/tp)** – Longest possible duration if challenges occur.
3. **Most likely time (M/tm)** – Expected duration under normal conditions.
4. **Critical path** - The longest path through the network, which determines the shortest time for project completion.

SOFTWARE FOR DEVELOPING PERT CHARTS

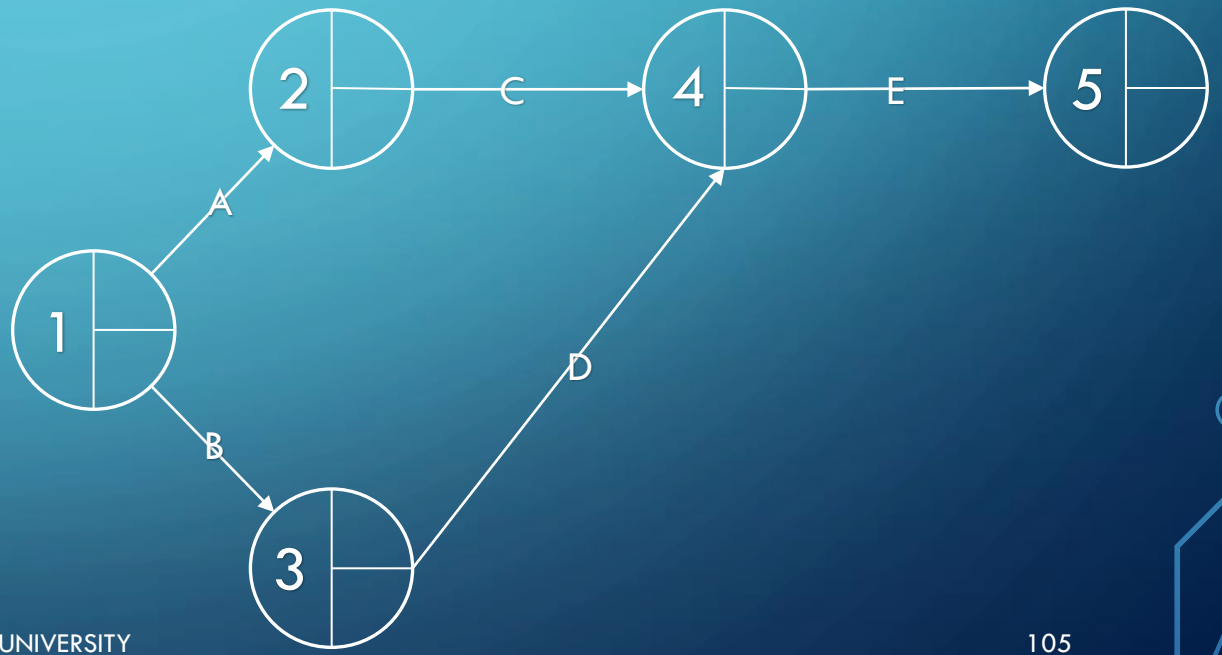
1. LucidChart
2. SmartDraw
3. EdrawMax
4. Creately
5. Microsoft Visio

PERT CHART EXAMPLE 1

- Question

Activities	Dependencies
A	
B	
C	A
D	B
E	C,D

- PERT Chart

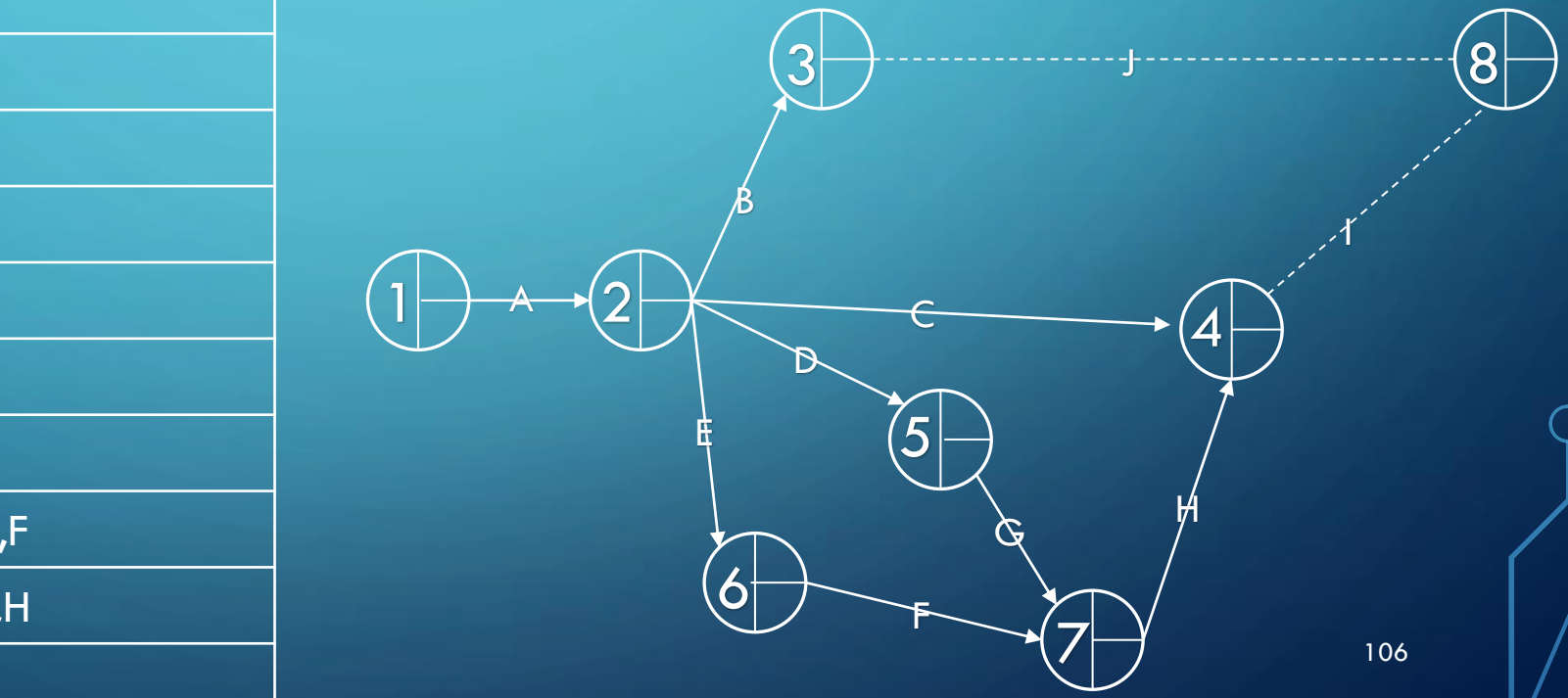


PERT CHART EXAMPLE 2

- Question

Activities	Dependencies
A	
B	A
C	A
D	A
E	A
F	E
G	D
H	G,F
I	C,H
J	B

- PERT Chart



PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

QUESTION

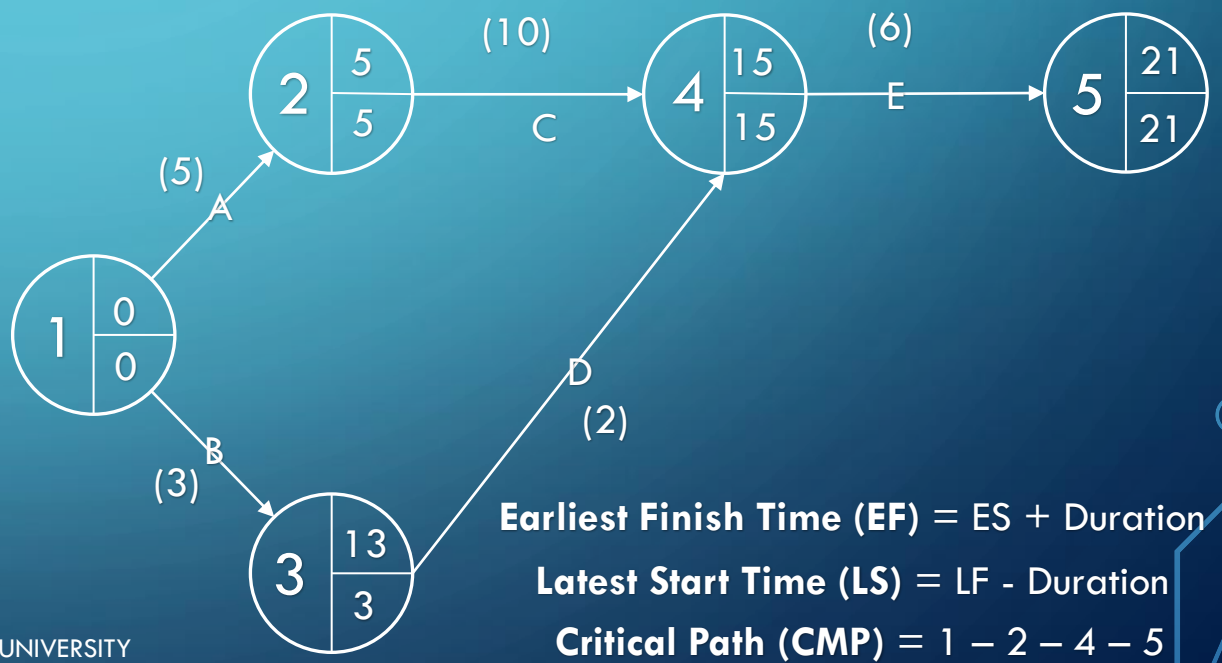
1. Construct a network diagram.
2. Find the critical path.
3. Determine the duration the project is likely to take you to complete.

PERT CHART EXAMPLE 3

1. Construct a network diagram.

Activities	Dependencies	Duration (Days)
A		5
B		3
C	A	10
D	B	2
E	C,D	6

- PERT Chart



Earliest Finish Time (EF) = ES + Duration

Latest Start Time (LS) = LF - Duration

Critical Path (CMP) = 1 – 2 – 4 – 5

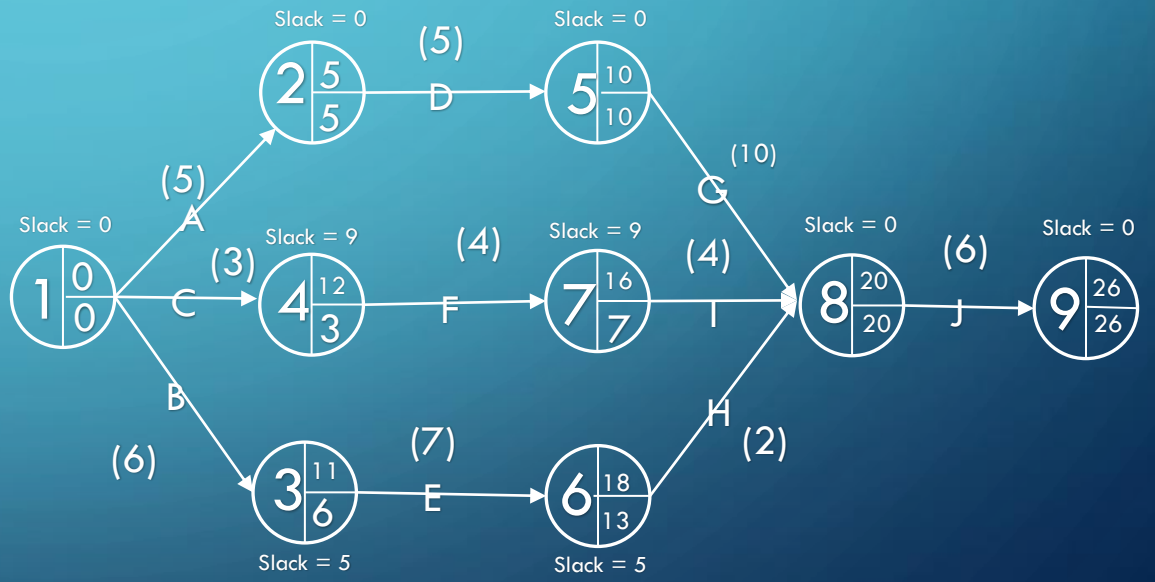
Duration of The Project = 5 + 10 + 6 = 21 Days

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

PERT CHART EXAMPLE 4

Activities	Dependencies	Duration (Days)
A		5
B		6
C		3
D	A	5
E	B	7
F	C	4
G	D	10
H	E	2
I	F	4
J	G,H,I	6

- PERT Chart



Critical Path (CMP) = 1 – 2 – 5 – 8 – 9

Total Duration = 5 + 5 + 10 + 6
= 26

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

PERT CHART

TASK 1

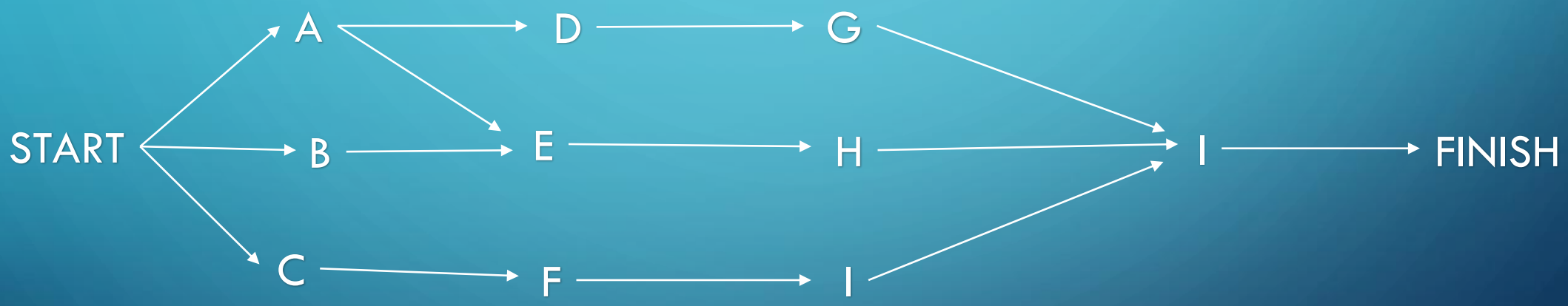
Activities	Dependencies	Duration (Days)
A		4
B		3
C		2
D	A	5
E	A,B	6
F	C	3
G	D	4
H	E	2
I	F	3
J	G,H,I	5

TASK 2

TASK ID	TASK DESCRIPTION	TASK PRE-DESSOR (S)	TASK DURATION (HOURS)
A	Project Starts		0
B	Buy Materials for A	A	10
C	Buy Materials for B	A	20
D	Build A	B,C	30
E	Build B	B,C	20
F	Finish building B	E	40
G	Join A and B	D,F	20
H	Finish Project	G	0

TASK 1

STECTCH



TASK 1 (CONTINUES…)

PERT CHART



A – D – G – J

Total Duration = 4 + 5 + 4 + 5
= 18 days

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

PERT CHART GUIDE

Activity	A	B	C	D	E	F	G
Immediate Predecessors			A	A,B	D	C,E	E
Expected Time (weeks)	7	9	12	8	9	6	5

A	ES	EF
t	LS	LF

KEY

A. Activities
t. Expected duration or Activity Time
ES. Earliest Start Time
EF. Earliest Finish Time
LS. Latest Start Time
LF. Latest Finish Time

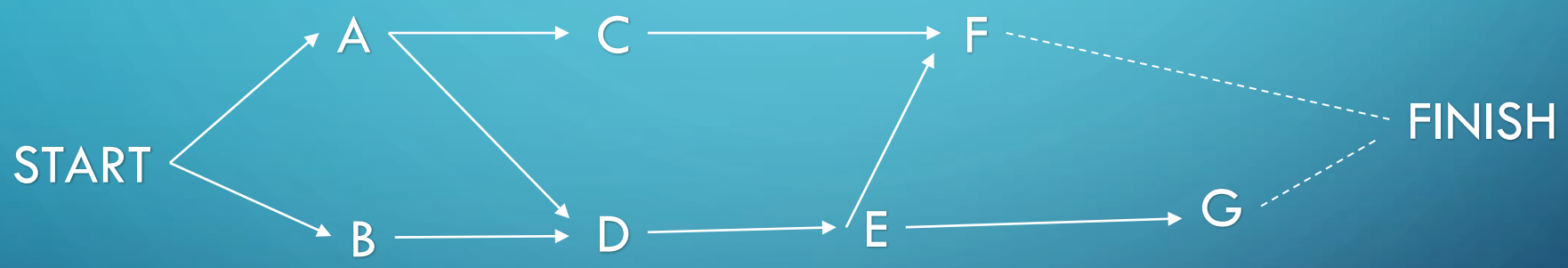
OBJECTIVES

1. Construct a project network
2. Perform forward and back passes
3. Determine project completion time
4. Calculate slack values
5. State the critical path

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

STEPS WHEN CREATING A PERT CHART

1. Create a draft or sketch.

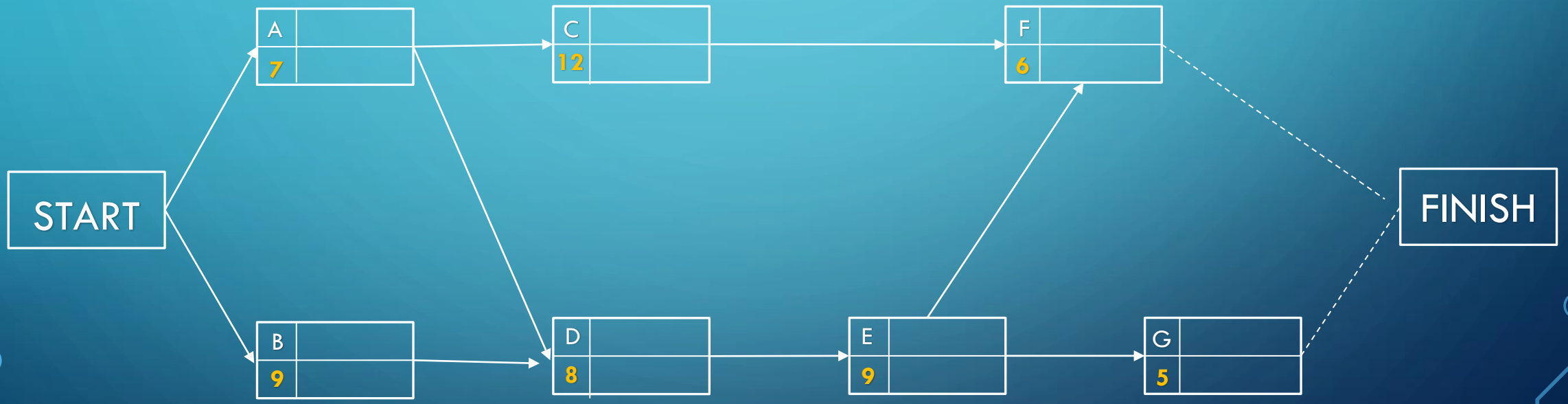


NOTE: Since F and G have nor predecessors they go to finish.

STEPS WHEN CREATING A PERT CHART (CONTINUES…)

KEY
Activity Time (t)

2. Creating the actual PERT Chart.

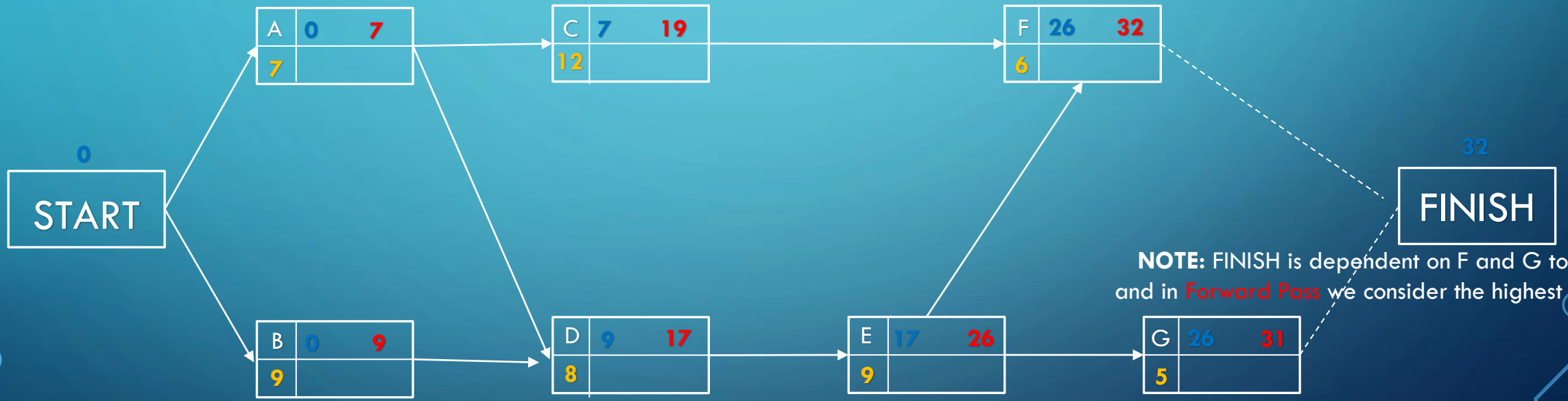


STEPS WHEN CREATING A PERT CHART (CONTINUES…)

KEY
Activity Time (t)
Forward Pass

3. Calculating the **Forward Pass: EF = ES + t**

NOTE: F is dependent on C and E to start and in Forward Pass we consider the highest EF (26)



NOTE: FINISH is dependent on F and G to stop and in Forward Pass we consider the highest EF (32)

NOTE: D is dependent on A and B to start and in Forward Pass we consider the highest EF (9)

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

STEPS WHEN CREATING A PERT CHART (CONTINUES…)

KEY
Activity Time (t)
Forward Pass
Backward Pass

4. Calculating the **Backward Pass: LS = LF - t**

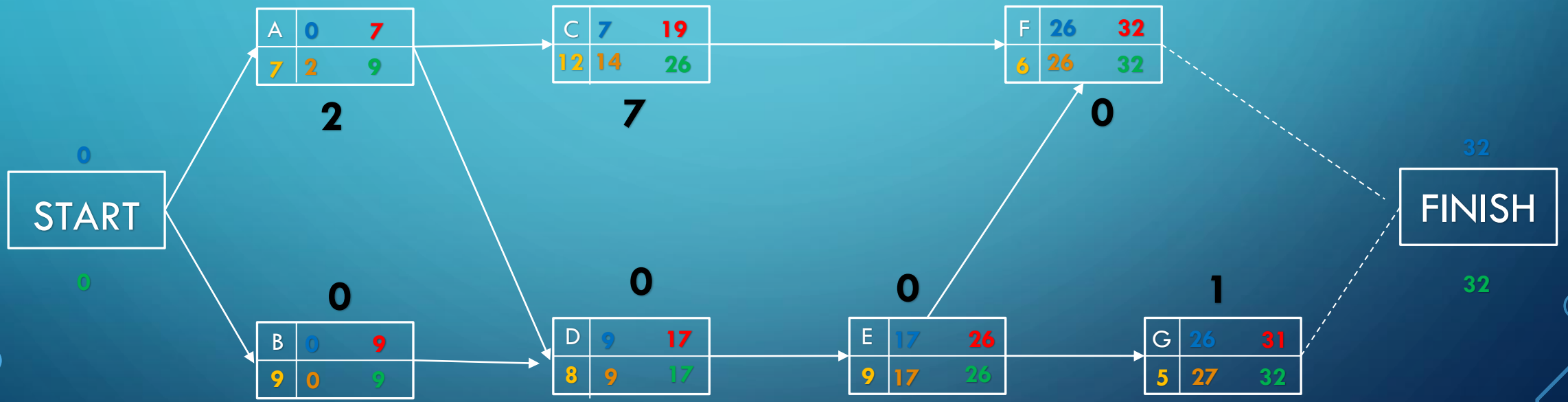


PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

STEPS WHEN CREATING A PERT CHART (CONTINUES…)

KEY
Activity Time (t)
Forward Pass
Backward Pass
Slack

5. Calculating the **Slack: LS – ES or LF - EF**

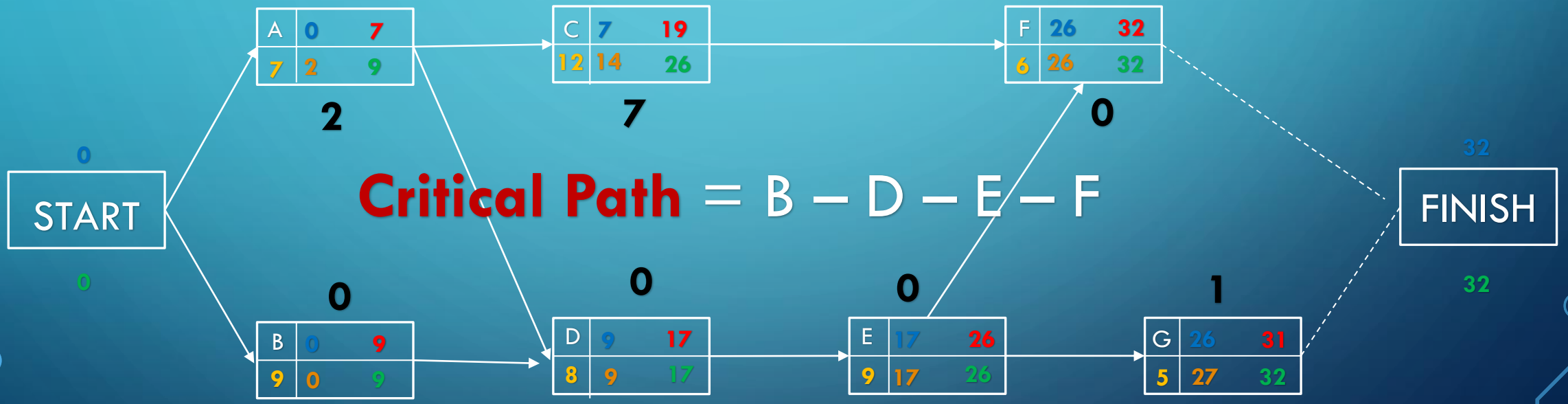


PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

STEPS WHEN CREATING A PERT CHART (CONTINUES…)

KEY
Activity Time (t)
Forward Pass
Backward Pass
Slack
Critical Path

6. Identifying the **Critical Path**: slack = 0



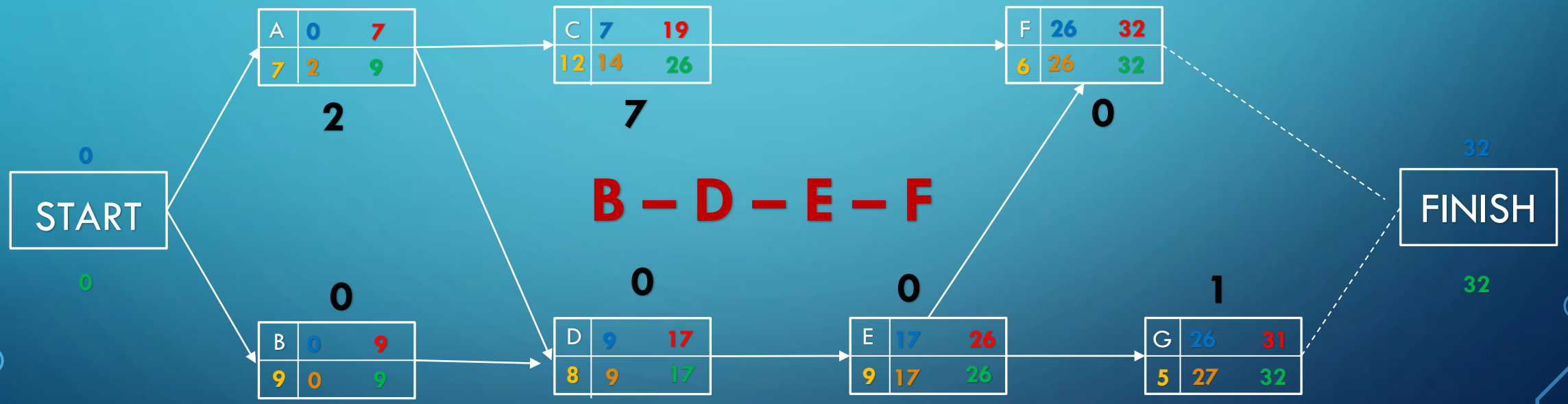
Total Duration = 9 + 8 + 9 + 6
= 32

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

STEPS WHEN CREATING A PERT CHART (CONTINUES…)

KEY
Activity Time (t)
Forward Pass
Backward Pass
Slack
Critical Path

7. Final PERT Chart

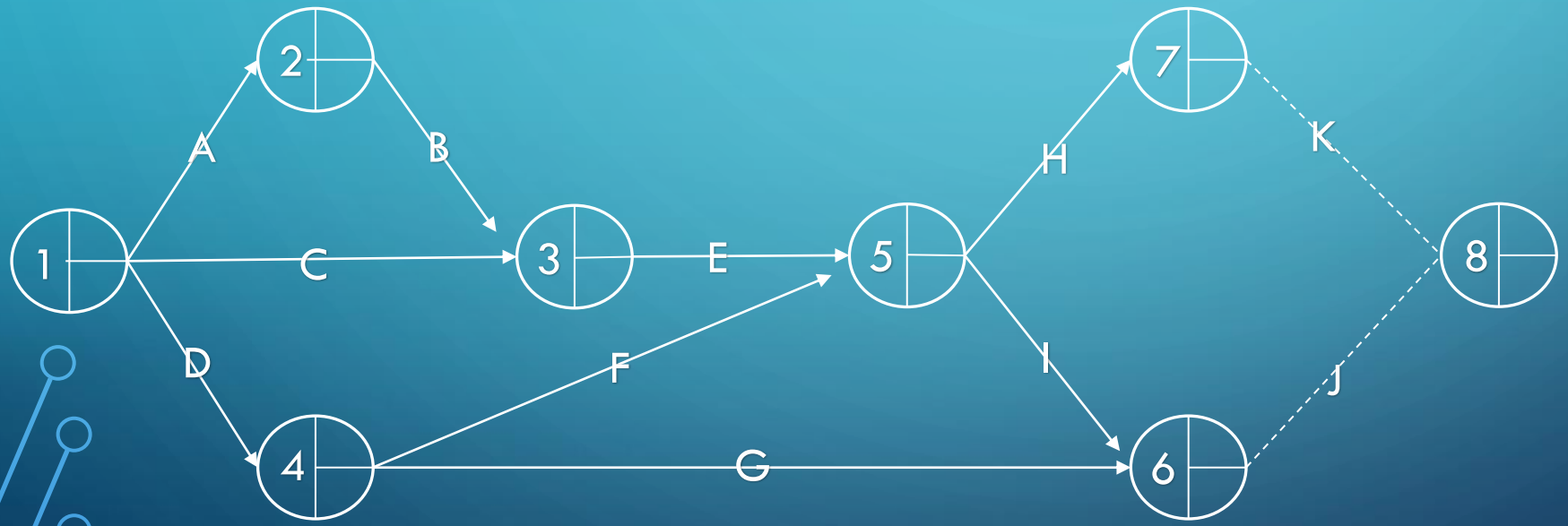


Total Duration = 9 + 8 + 9 + 6
= 32

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

EXAMPLE 5

- E > B, C; F, G > D; H,I > E, F; J > I, G; K > H; B > A



Activities	Predecessors
A	
B	A
C	
D	
E	B, C
F	D
G	D
H	E, F
I	E, F
J	I, G
K	H

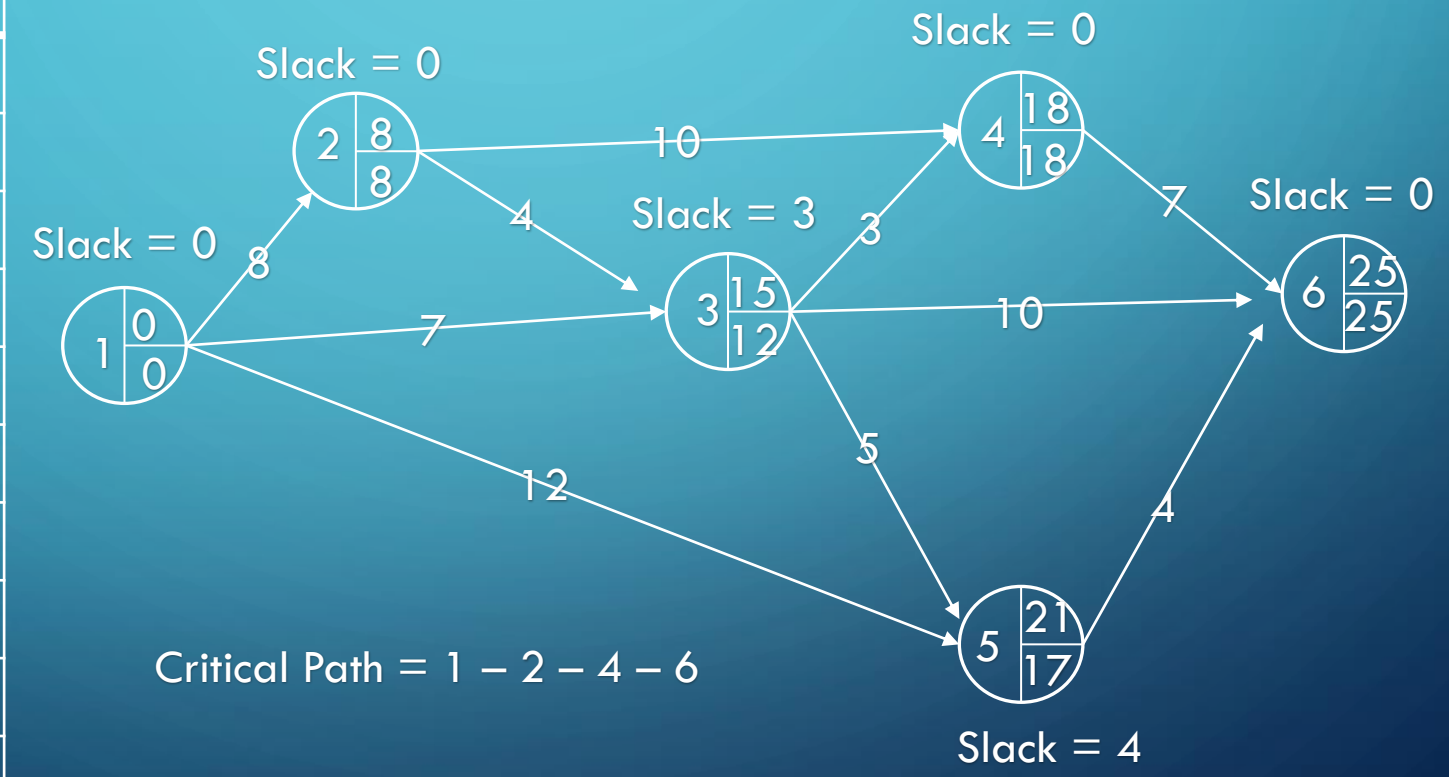
PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

TASK 3

1. Calculate the Earliest Finish (**EF**), Eeliest Start (**ES**), Latest Finish (**LF**) and Latest Start (**LS**).
2. Compute the Total Float (**TF**), Free Float (**FF**), Independent Float (**IND F**) and Interfering Float **(INT F**).

TASK 3 (CONTINUES…) – NETWORK DIAGRAM

Activities	Duration
1 – 2	8
1 – 3	7
1 – 5	12
2 – 3	4
2 – 4	10
3 – 4	3
3 – 5	5
3 – 6	10
4 – 6	7
5 – 6	4



PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

TASK 3 (CONTINUES…) – ES, EF, LF, LS & TF

Activities	ES	Duration	EF (ES + D)
1 – 2	0	8	8
1 – 3	0	7	7
1 – 5	0	12	12
2 – 3	8	4	12
2 – 4	8	10	18
3 – 4	12	3	15
3 – 5	12	5	17
3 – 6	12	10	22
4 – 6	18	7	25
5 – 6	17	4	21

Activities	LF	Duration	LS (LF - D)
1 – 2	8	8	0
1 – 3	15	7	8
1 – 5	21	12	9
2 – 3	15	4	11
2 – 4	18	10	8
3 – 4	18	3	15
3 – 5	21	5	16
3 – 6	25	10	15
4 – 6	25	7	18
5 – 6	25	4	21

LS	ES	TF (LS - ES)
0	0	0
8	0	8
9	0	9
11	8	3
8	8	0
15	12	3
16	12	4
15	12	3
18	18	0
21	17	4

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

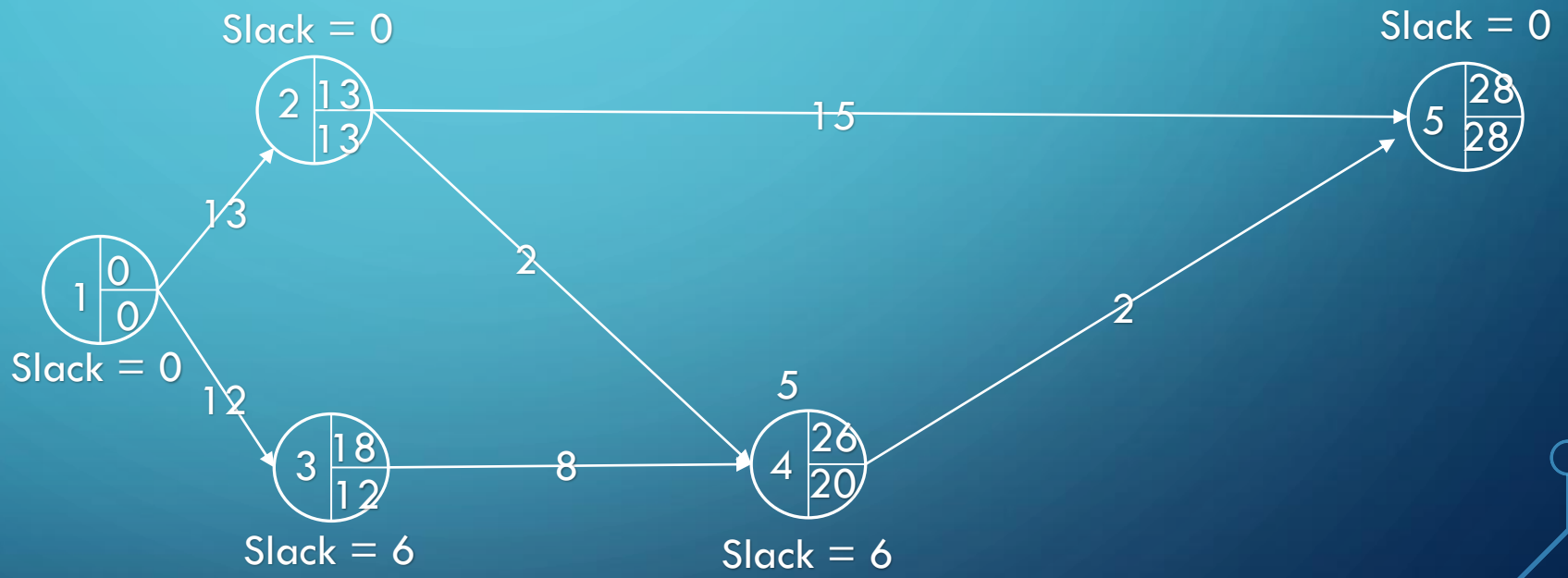
TASK 3 (CONTINUES…) – FF, IND F & INT F

Activities	T	H	TF	FF (TF – H)	IND F (FF – T)	INT F (TF – FF)
1 – 2	0	0	0	0	0	0
1 – 3	0	3	8	5	5	3
1 – 5	0	4	9	5	5	4
2 – 3	0	3	3	0	0	3
2 – 4	0	0	0	0	0	0
3 – 4	3	0	3	3	0	0
3 – 5	3	4	4	0	-3	4
3 – 6	3	0	3	3	0	0
4 – 6	0	0	0	0	0	0
5 – 6	4	0	4	4	0	0

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

TASK 4

Activities	Duration
1 – 2	13
1 – 3	12
2 – 4	2
3 – 4	8
2 – 5	15
4 – 5	2



Critical Path = 1 – 2 – 5

Total Duration = 13 + 15
= 28

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

TASK 4 (CONTINUES…) – ES, EF, LF, LS & TF

Activities	ES	Duration	EF (ES + D)
1 – 2	0	13	13
1 – 3	0	12	12
2 – 4	13	2	15
3 – 4	12	8	20
2 – 5	13	15	28
4 – 5	20	2	22

Activities	LF	Duration	LS (LF - D)
1 – 2	13	13	0
1 – 3	18	12	6
2 – 4	26	2	24
3 – 4	26	8	18
2 – 5	28	15	13
4 – 5	28	2	26

LS	ES	TF (LS - ES)
0	0	0
6	0	6
24	13	11
18	12	6
13	13	0
26	20	6

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

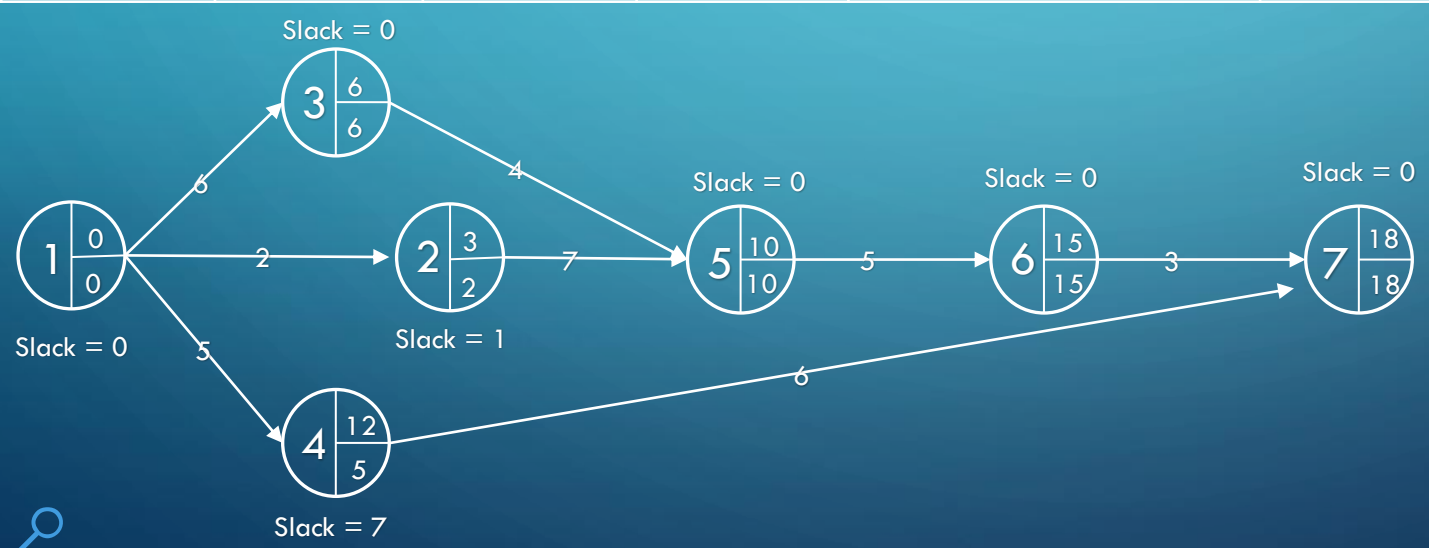
TASK 4 (CONTINUES…) – FF, IND F & INT F

Activities	T	H	TF	FF (TF – H)	IND F (FF – T)	INT F (TF – FF)
1 – 2	0	0	0	0	0	0
1 – 3	0	6	6	0	0	6
2 – 4	0	6	11	5	5	6
3 – 4	6	6	6	0	-6	6
2 – 5	0	0	0	0	0	0
4 – 5	6	0	6	6	0	0

UP NEXT… EXAMPLE 7

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

Activity	Optimistic (O or to)	Pessimistic (P or tp)	Most Likely (M or tm)	4tm	Te = (to + 4tm + tp) / 6	σ = (tp – to) / 6	σ²
1 – 2	1	3	2	4(2) =8	(1 + 8 + 3) / 6 = 2	(3 – 1) / 6 = 0.33	0.10
1 – 3	5	7	6	4(6) = 24	(5 + 12 + 7) / 6 = 6	(7 – 5) / 6 = 0.33	0.10
1 – 4	3	7	5	4(5) = 20	(3 + 20 + 7) / 6 = 5	(7 – 3) / 6 = 0.66	0.43
2 – 5	5	9	7	4(7) = 28	(5 + 28 + 9) / 6 = 7	(9 – 5) / 6 = 0.66	0.43
3 – 5	2	6	4	4(4) = 16	(2 + 16 + 6) / 6 = 4	(6 – 2) / 6 = 0.66	0.43
5 – 6	4	6	5	4(5) = 20	(4 + 20 + 6) / 6 = 5	(6 – 4) / 6 = 0.33	0.10
4 – 7	4	8	6	4(6) = 24	(4 + 24 + 8) / 6 = 6	(8 – 4) / 6 = 0.66	0.43
6 – 7	2	4	3	4(3) = 12	(2 + 12 + 4) /6 = 3	(4 – 2) / 6 = 0.33	0.10



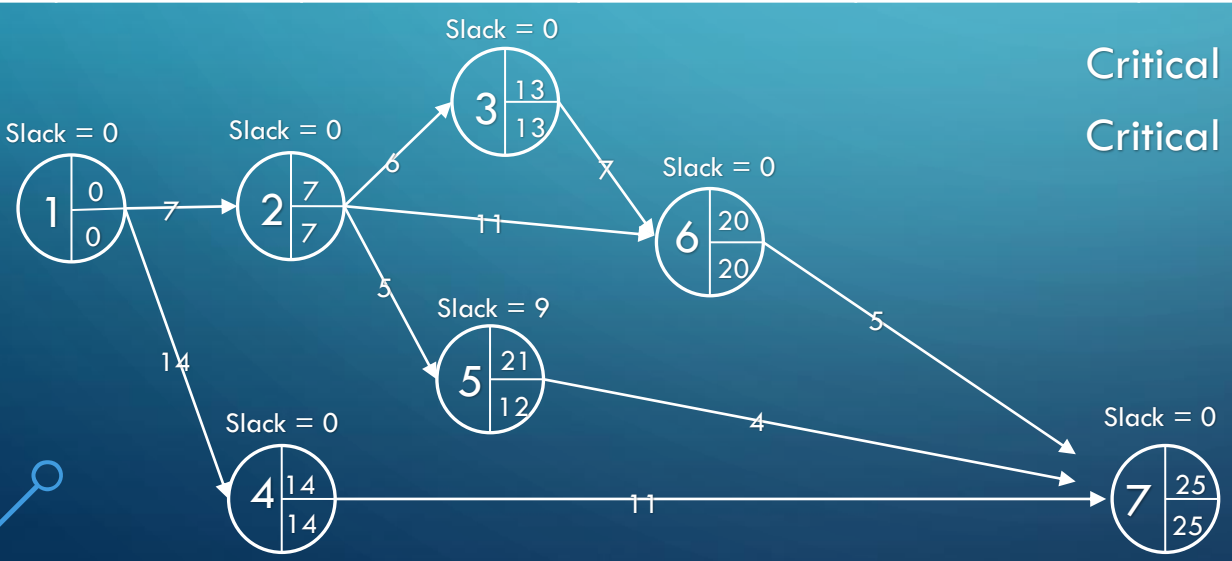
Critical Path = 1 – 3 – 5 – 6 – 7

Critical Variance = 0.10 + 0.43 + 0.10 + 0.10 = 0.73

Total Duration = 6 + 4 + 5 + 3 = 18

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

Activity	Optimistic (O or to)	Pessimistic (P or tp)	Most Likely (M or tm)	4tm	Te = to + 4tm + tp	σ = (tp – to) / 6	σ²
1 – 2	3	15	6	4(6) = 24	(3 + 24 + 15) / 6 = 7	(15 – 3) / 6 = 2	4
2 – 3	2	14	5	4(5) = 20	(2 + 20 + 14) / 6 = 6	(14 – 2) / 6 = 2	4
1 – 4	6	30	12	4(12) = 48	(6 + 48 + 30) / 6 = 14	(30 – 6) / 6 = 4	16
2 – 5	2	8	5	4(5) = 20	(2 + 20 + 8) / 6 = 5	(8 – 2) / 6 = 1	1
2 – 6	5	17	11	4(11) = 44	(5 + 44 + 17) / 6 = 11	(17 – 5) / 6 = 2	4
3 – 6	3	15	6	4(6) = 24	(3 + 24 + 15) / 6 = 7	(15 – 3) / 6 = 2	4
4 – 7	3	27	9	4(9) = 36	(3 + 36 + 27) / 6 = 11	(27 – 3) / 6 = 4	16
5 – 7	1	7	4	4(4) = 16	(1 + 16 + 7) / 6 = 4	(7 – 1) / 6 = 1	1
6 – 7	2	8	5	4(5) = 20	(2 + 20 + 8) / 6 = 5	(8 – 2) / 6 = 1	1



Critical Path = 1 – 4 – 7

Critical Variance = 16 + 16
= 32

Total Duration = 14 + 11
= 25

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

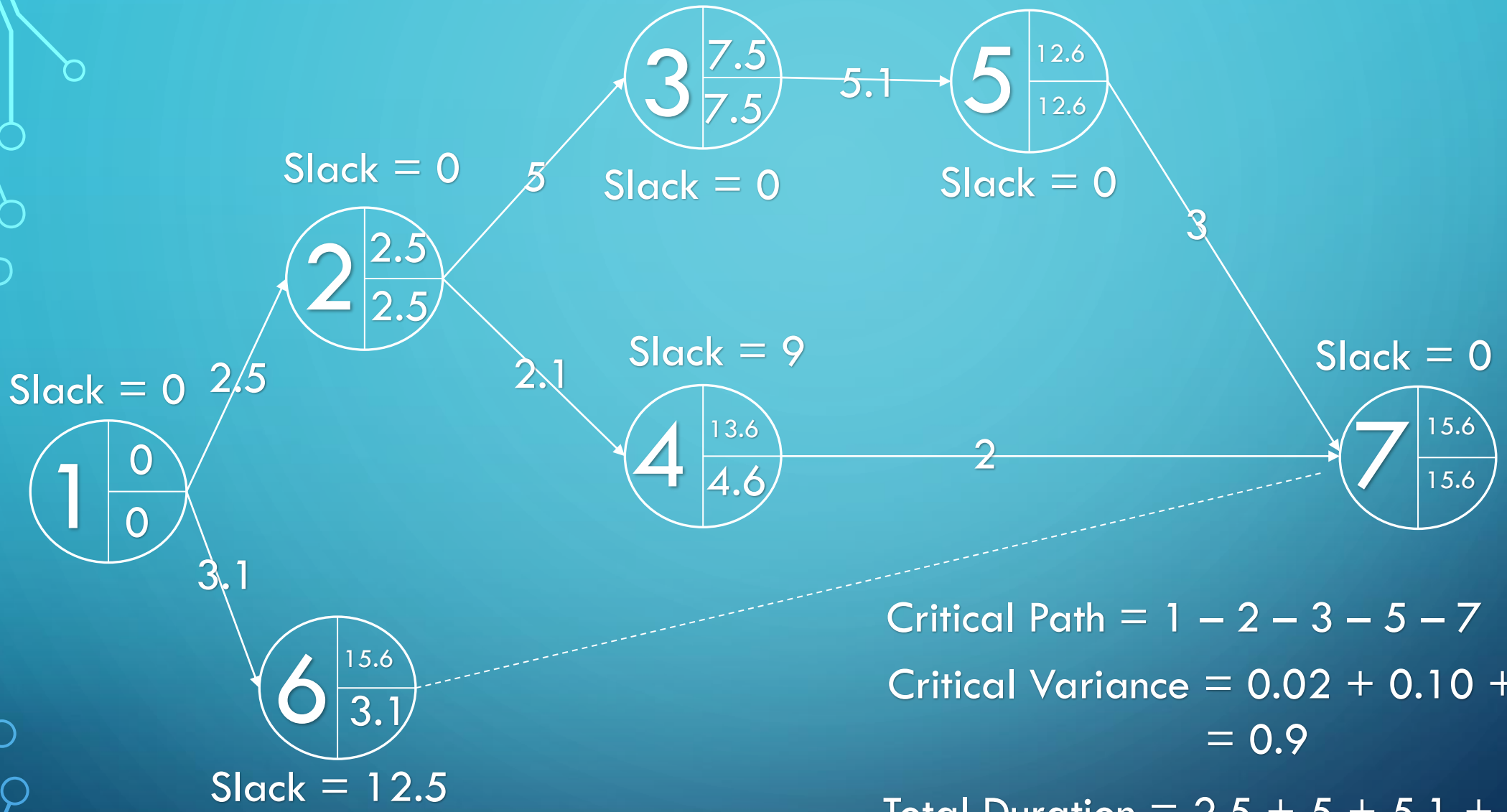
TASK 5

Activity	O	P	M	Dependences
Identify compromised systems	1	2	3	None
Patch vulnerabilities	2	4	6	Identify compromised vulnerabilities
Secure User Accounts	1	4	2	Patch vulnerabilities
Restore data	3	8	5	Patch vulnerabilities
Implement additional controls	2	5	3	Secure User Accounts
Revise Policies	1	3	2	Identify compromised systems
Final audit and testing	2	4	3	Implement additional controls, restore data

TASK 5 (CONTINUES…)

		Dependence		Activity	to	tp	tm	4tm	Te	σ	σ^2
1	Identify Compromised Systems										
2	Path Vulnerability	1		1 – 2	1	2	3	12	2.5	0.16	0.02
3	Secure User Accounts	2		2 – 3	2	4	6	24	5	0.33	0.10
4	Restore Data	2		2 – 4	1	4	2	8	2.1	0.5	0.25
5	Implement additional Controls	3		3 – 5	3	8	5	20	5.1	0.83	0.68
6	Revise polices	1		1 – 6	2	5	3	12	3.1	0.5	0.25
7	Final Audit and Testing	5,4		4 – 7	1	3	2	8	2	0.33	0.10
				5 – 7	2	4	3	12	3	0.33	0.10

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY



Critical Path = 1 – 2 – 3 – 5 – 7

Critical Variance = 0.02 + 0.10 + 0.68 0.10
= 0.9

Total Duration = 2.5 + 5 + 5.1 + 3
= 15.6



	ACTIVITY	DEPENDANCE		ACTIVITIES
1	Root cause analysis			**1 – 2**
2	Patch development	Root cause analysis		**2 – 3**
3	Pact testing	Patch development		**3 – 5**
4	Schedule Maintenance	Pact testing		**3 – 4**
5	Deploy patch	Pact testing		*4 – 5*
6	Validate remediation	Deploy patch		**5 – 6**
7	Update documentation	Validate remediation		**6 – 7**
8	Notify stakeholders	Update documentation, Deploy patch		*7 – 8* *5 – 8*

PREPARED BY JAMES SOKO FOR MR. PAUL M. MUTUNDA © 2025 KAPASA MAKASA UNIVERSITY

AAA

UNIT 3

AAA

- **Authentication**, **Authorization** and **Accounting** (**AAA**) is crucial security framework that controls and monitors user access to network resources.
- How AAA mitigates vulnerabilities in a network:

1. **Authentication** – verifies the identity of user or device requesting access, typically, using credentials such as passwords, tokens, or biometrics.
2. **Authorization** – determines the permissions and what resources the authenticated user is allowed to access or actions they can perform.
3. **Accounting** – Tracks and logs user activities for auditing, compliance, and resource usage monitoring.

IMPORTANCE OF AAA IN A NETWORK SECURITY AGAINST VULNERABILITIES

1. It **strengthens network security** by ensuring that only legitimate users login or gain access to resources, enforcing access control policies and maintaining an audit trail of user actions for accountability and security investigations.
2. It **helps in compliance with security standards** and detecting unauthorized activities.

PROTOCOLS AND IMPLANTATION

1. **Remote Authentication Dial-In User Service (RADIUS)** – Provides centralized authentication, authorization, and accounting primarily for remote network access.
2. **Terminal Access Controller Access – Control System Plus (TACACS+)** – Offers similar functions with additional support for command – level authorization and device administration.

DIFFERENCES BETWEEN RADIUS AND TACACS+

Features	RADIUS	TACACS+
Protocol	UDP	TCP
Transport characteristics	Connectionless, faster, but less reliable	Connection oriented, more reliable
Encryption	Encrypts only the password in the packet	Encrypts the entire packet payload
AAA	Combined process	Separate processes
Accounting support	Strong accounting capabilities	Accounting separate
Typical use	Remote user network access authentication	Device administration (routers, switches)
Vendor support	Open standard widely supported	CISCO proprietary but widely used
Authorised control	Limited command – level authorization	Granular control commands management
Use case	Best for authentication remote users (Wi-Fi, VPN)	Best for managing device administration and command authorization

SECURITY BENEFITS OF AAA

DUE TO TIME, THIS HANDOUT IS NOT COMPLETE, USE IT TO ANSWER THE QUESTIONS